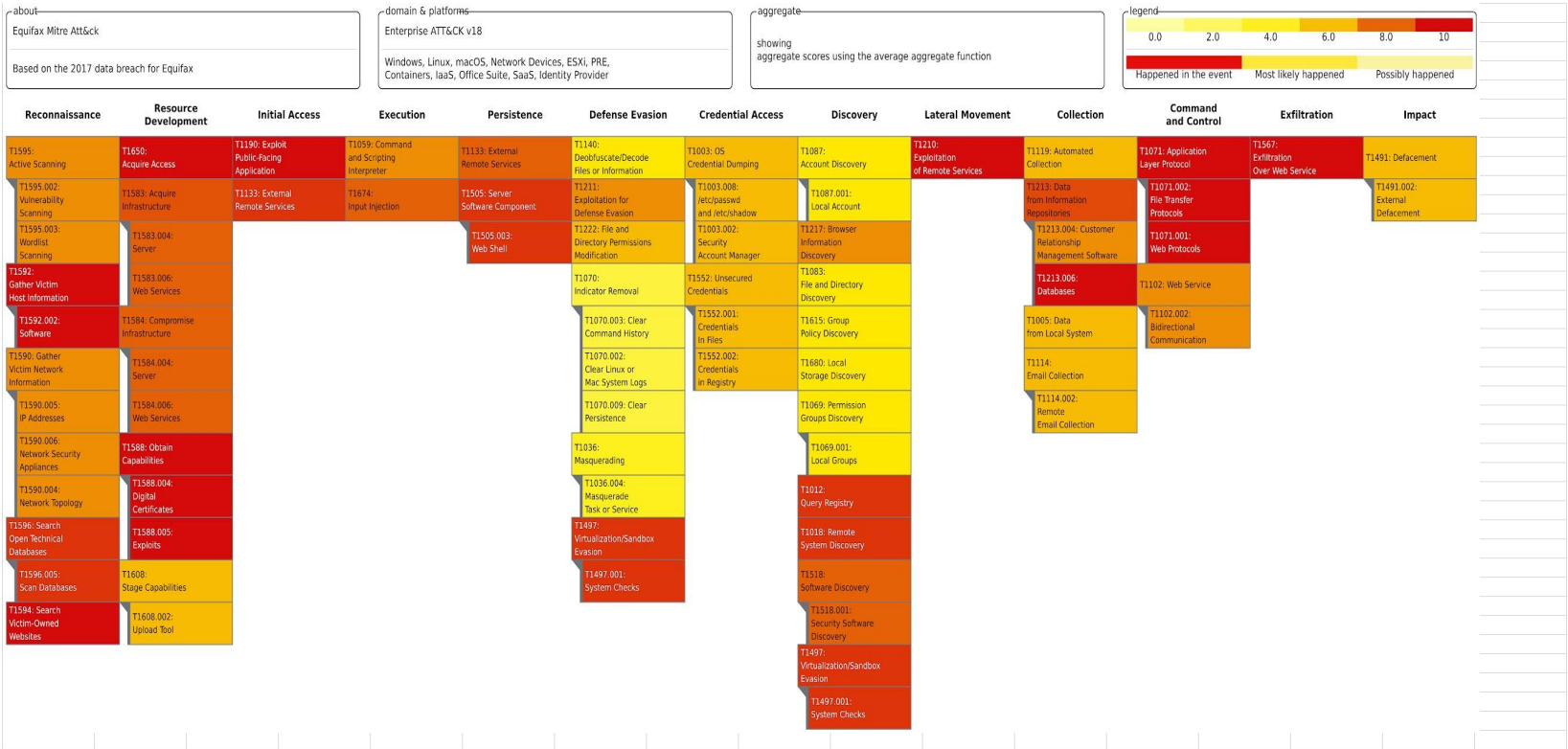


MITRE ATT&CK Mapping Report	
Equifax Data Breach - 2017	
04-07-2026	
By: Daniyal Anwar & Anna Fanco	
Executive Summary	
The Equifax breach was one of the most significant data theft incidents in U.S. history. Public reporting and congressional investigation show that attackers exploited a vulnerable Apache Struts web application used in Equifax's online dispute portal. After gaining access, the attackers installed web shells, found unencrypted credentials in a file, pivoted to additional databases, and extracted large volumes of personally identifiable information. The House Oversight report states that the attack began on May 13, 2017 and lasted 76 days. Attackers used approximately 30 web shells, accessed 48 unrelated databases using exposed credentials, issued about 9,000 queries, and successfully retrieved sensitive PII through 265 successful database searches before compressing and exfiltrating the data. The breach was not detected sooner because a monitoring device had been inactive due to an expired security certificate.	
Report Contents	
1) Cover Page	
2) Navigator Map (SVG placeholder)	
3) ATT&CK Mapping (Excel export style table)	
4) Incident Debrief / Recommendations	



Legend	
	Happened in the event
	Most likely happened during event
	Potentially happened during the event

Incident Debrief				
Findings & Recommendations				
The Equifax incident was a long data exfiltration operation enabled by a known but unpatched internet-facing vulnerability, weak secrets management, insufficient segmentation, and failed monitoring. The attackers did not need to deploy ransomware or cause disruption. Instead, they stayed focused on persistence, credential abuse, database access, collection, compression, and exfiltration.				
The most important defensive lessons and security recommendations are straightforward: patch public-facingapps rapidly, monitor web-tier integrity, remove plaintext credentials from files and shares, tightly segment systems that handle regulated data, and validate that network monitoring controls are actually functioning. In addition new system should be added to include auditing all certificates, setting renewal reminders, and automating the process to ensure that no other certificates expire. For ATT&CK mapping, this case is a strong example of how Initial Access, Persistence, Credential Access, Discovery, Collection, and Exfiltration can chain together in a classic data theft campaign.				
Tactics	Techniques	Threat Actor Artifacts/Activity	Detection Recommendations	
TA0043: Reconnaissance	T1595: Active Scanning: T1595.002: Vulnerability Scanning	Threat actor likely scanned internet facing systems and identified vulnerable systems. One of which likely was the Apache based dispute portal	Monitor perimeter firewall and IDS logs for unusual and repeated probing, unusual URL requests and scanning patterns from the same host address	
TA0043: Reconnaissance	T1592: Gather Victim Host Information : T1592.002: Software	Likely gathered information about the software in use and web server information and other application details that supported in exploitation	Track exposure and alerts on all public facing interfaces and monitor these systems	
TA0043: Reconnaissance	T1596: Search Open Technical Databases: T1596.005: Scan Databases	Actor may have reviewed vulnerability sources and exploit information related to Apache databases and similar enterprise web technology before intrusion.	Track known CVEs that affect public facing systems and validate that critical flaws are remediated quickly and effectively	
TA0043: Reconnaissance	T1594: Search Victim-Owned Websites	Threat actor likely reviewed Equifax owned websites to identify entry points	Inventory all public facing web assets and monitor access logs for any enumeration or unusual browsing patterns	
TA0042: Resource Development	T1650: Acquire Access	Actor likely prepared to obtain authorization access through a viable exploit	Correlate CTI on actors targeting new vulnerabilities and watch for exploit attempts.	
TA0042: Resource Development	T1588: Obtain Capabilities: T1588.004: Digital Certificates	Actor may have obtained tools used to make malicious traffic appear more legitimate	Monitor certificate usage and observe TLS infrastructure	
TA0042: Resource Development	T1588: Obtain Capabilities: T1588.005: Exploits	Threat actor may have acquired Apache exploit code to use against the dispute portal	Usage of intrusion detection signatures and WAF protections would help here	
TA0001: Initial Access	T1190: Exploit Public-Facing Application	Threat actor may have initially accessed online dispute portal through the exploitation of unpatched Apache vulnerability.	Setup alerts, especially on suspicious injection patterns, or application crashes launched by web services or anomalous requests	
TA0001: Initial Access	T1133: External Remote Services	After initial exploitation, actor may have used remote services to maintain access to environment	Restrict remote service exposure by requiring MFA where possible and log authentication attempts. Also setup alerts on unusual remote access from unfamiliar sources	
TA0002: Execution	T1674: Input Injection	Actor likely used input through web application to execute actions on server after exploiting Apache flaw.	Monitor application logs and alerts for malicious input patterns and unexpected requests by abnormal server side activity	
TA0003: Persistence	T1505: Server Software Component: T1505.003: Web Shell	Threat actor likely established persistence by placing web shell allowing them continued access after intrusion	Monitor web directories for unauthorized modification and setup alerts for suspicious scripts and watch logs for shell activity	
TA0003: Persistence	T1133: External Remote Services	The actor may have maintained access through externally reachable remote service paths	Review authentication logs for unusual source IPs and setup alerts for repeated successful access from unfamiliar locations	
TA0005: Defense Evasion	T1211: Exploitation for Defense Evasion	Threat actor likely exploited system weakness not only for access but also to avoid security controls and remain active without immediate detection	Monitor for abuse of trusted processes, unusual privilege changes, and suspicious behavior tied to exploited applications that bypasses normal control paths.	
TA0005: Defense Evasion	T1497: Virtualization/Sandbox Evasion: T1497.001: System Checks	The actor or tooling may have checked the environment to determine whether it was being analyzed	Alert on environment checking commands, VM artifact checks, debugger checks, and suspicious logic	
TA0007: Discovery	T1012: Query Registry	The actor may have queried system or application configuration data to identify useful settings or credentials	Monitor registry access by unusual processes, especially web server spawned processes, and alert on reads of sensitive configuration or credential related registry locations.	
TA0007: Discovery	T1018: Remote System Discovery	Threat actor likely looked for other internal systems after compromising external server	Setup host detection and host based network enumeration. Also scan logs for unusual internal scanning from web servers and connections from DMZ systems to systems that they do not regularly contact	
TA0008: Lateral Movement	T1210: Exploitation of Remote Services	After gaining access the threat actor likely moved deeper into the system by abusing trusted connections or vulnerable remote services.	Segment critical systems and setup alerts on new admin or database connections from internet servers.	
TA0009: Collection	T1213: Data from Information Repositories: T1213.006: Databases	The actor likely accessed sensitive Equifax records from back end databases and gathered large volumes of personal data for later theft.	Monitor database queries for abnormal volumes, unusual account behavior and large result sets	
TA0011: Command and Control	T1071: Application Layer Protocol: T1071.002: File Transfer Protocols	Threat actor likely used common application layer traffic including ftp to communicate with external servers.	Inspect outbound traffic for unusual file transfer behavior, rare destinations, repeated sessions, and unexpected protocol use from servers that should not initiate such communications.	
TA0011: Command and Control	T1071: Application Layer Protocol: T1071.001: Web Protocols	The threat actor likely used HTTP for command and control as web traffic is more common and less likely to raise suspicion immediately.	Use proxy and firewall logging. Also monitor encrypted sessions on the web server and restrict any outbound web access.	
TA0010: Exfiltration	T1567: Exfiltration Over Web Service	The actor likely exfiltrated stolen data over web based services or web traffic channels to attacker controlled servers making the activity resemble normal outbound traffi	Alert on unusual outbound transfer size, compressed or archived data leaving sensitive hosts	

References									
Amishav, J. (2026, January 26). Equifax Data Breach 2017: Timeline, \$1.38B Cost & Lessons. Breachsense.com; Breachsense. https://www.breachsense.com/blog/equifax-data-breach/#what-is-the-equifax-data-breach-timeline									
(2024). Github.io. https://mitre-attack.github.io/attack-navigator/#bundleURL=https%3A%2F%2Fraw.githubusercontent.com%2Fmitre%2Fcti%2FATT%26CK-v8.2%2Fenterprise-attack%2Fenterprise-attack.json&version=8.2&domain=enterprise-attack									
U.S. House of Representatives Committee on Oversight and Government Reform. (2018). U. S. House of Representatives Committee on Oversight and Government Reform The Equifax Data Breach Majority Staff Report 115th Congress. https://oversight.house.gov/wp-content/uploads/2018/12/Equifax-Report.pdf									
Equifax Data Breach: What Happened, Impact, and Lessons Huntress. (2017). Huntress. https://www.huntress.com/threat-library/data-breach/equifax-data-breach									
Techniques - Enterprise MITRE ATT&CK®. (n. d.). Attack.mitre.org. https://attack.mitre.org/techniques/									